

Vulnerability Assessment & Security Analysis of Windows Server 2012/2016 Virtual Machines

Parth Patel

May 14, 2026

Table of Contents

1.0 Introduction.....	3
2.0 Tools and Technologies.....	3
3.0 Environment Setup.....	3
4.0 Methodology.....	4
5.0 Scan Results.....	5
5.1 Windows Server 2016.....	5
5.2 Windows Server 2012.....	12
6.0 Vulnerability Analysis.....	16
7.0 Prioritized Risk Register and Overall Risk Approach.....	23
8.0 Recommendations for Remediation.....	26
9.0 Next Steps and Validation Activities.....	27
10.0 Lessons Learned.....	28
11.0 Conclusion.....	29

1.0 Introduction

This report presents a vulnerability assessment conducted on a Windows Server 2012 virtual machine using Nessus, along with network scanning and port enumeration performed on both Windows Server 2016 and Windows Server 2012 using Nmap (Zenmap). The objective was to identify security weaknesses, analyze potential risks, and recommend appropriate mitigation strategies.

All scanning activities were performed strictly for educational and penetration testing purposes on authorized systems within a virtual lab environment. No unauthorized scanning was conducted, as performing vulnerability scans on systems without proper permission is unethical and may violate legal and organizational policies.

2.0 Tools and Technologies

Tool	Purpose
Nessus	Vulnerability Scanning and Risk Assessment
Nmap (Zenmap)	Network Scanning and Port Enumeration
Kali Linux	Penetration Testing
Oracle VirtualBox	Hosting the virtual environment and setup

3.0 Environment Setup

Component	Description
Attacker Machine	Kali Linux
Target Machine 1	Windows Server 2016 (172.16.87.16)
Target Machine 2	Windows Server 2012 (172.16.87.12)

VULNERABILITY SCANNING AND SECURITY ASSESSMENT

Project Architecture and Workflow

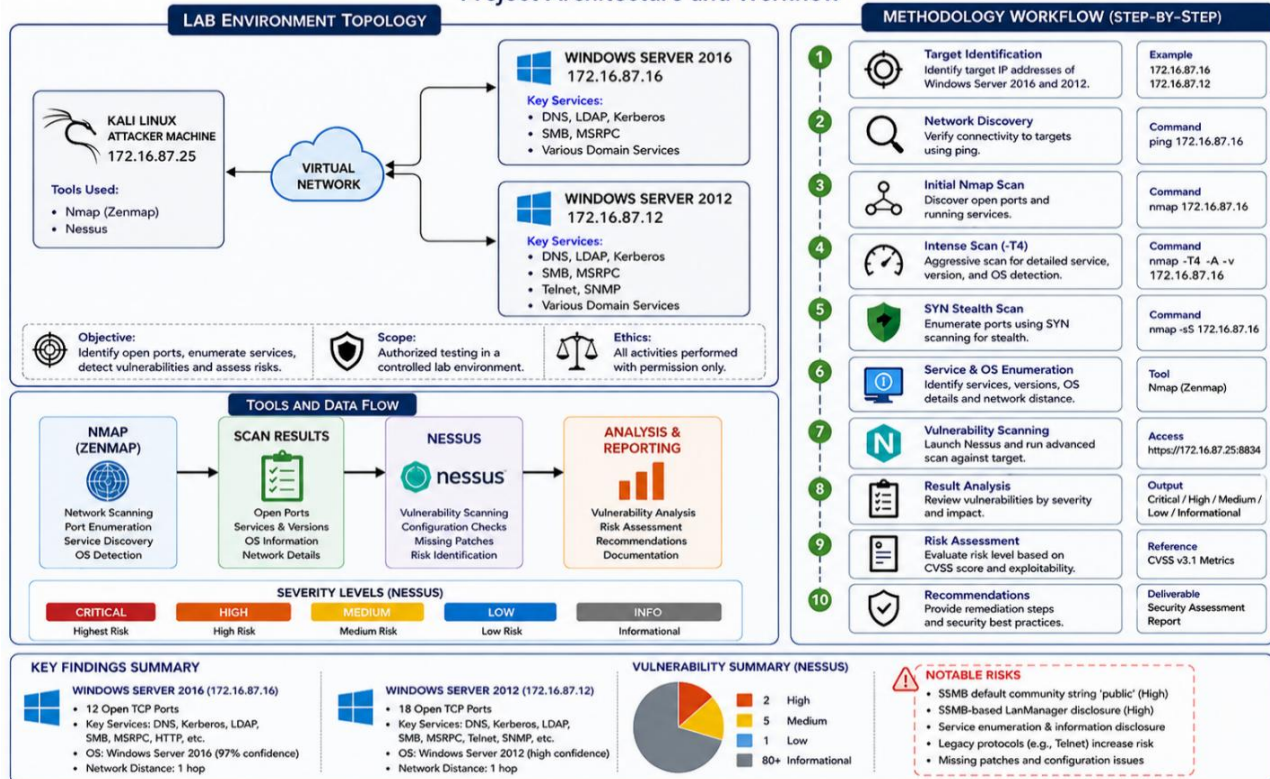


Figure 1: Illustration of the lab environment topology, scanning workflow, tools used throughout the assessment, and the overall vulnerability assessment methodology.

4.0 Methodology

The vulnerability assessment was conducted using a structured approach to identify open ports, enumerate services, and detect potential security weaknesses within the target systems. Both network scanning and vulnerability scanning techniques were applied to ensure comprehensive coverage.

The following steps were performed:

- Target Identification**
 Identified the IP addresses of the target systems (Windows Server 2012 and 2016) within the virtual network environment.
- Network Scanning (Nmap/Zenmap)**
 Performed initial reconnaissance using Nmap (Zenmap) to discover active hosts, open ports, and running services.

- **Slow Comprehensive Scan**
Executed a detailed scan to analyze both **TCP and UDP ports**, ensuring thorough detection of services and minimizing the likelihood of missed vulnerabilities.
- **Intense Scan (-T4 Timing)**
Conducted a faster scan using aggressive timing to quickly identify open ports, services, and operating system details.
- **SYN Stealth Scan**
Utilized SYN-based scanning to enumerate ports without completing full TCP handshakes, reducing detection likelihood and simulating real-world attacker behavior.
- **Service and OS Enumeration**
Identified running services, service versions, and operating system details to assess potential vulnerabilities associated with each service.
- **Vulnerability Scanning (Nessus)**
Performed an advanced vulnerability scan using Nessus to identify known vulnerabilities and misconfigurations, categorized by severity levels (Critical, High, Medium, Low).
- **Result Analysis and Classification**
Analyzed scan outputs and prioritized vulnerabilities based on severity, exploitability, and potential impact using standardized risk metrics.

5.0 Scan Results

5.1 Windows Server 2016

Multiple scans were conducted on the Windows Server 2016 system using Nmap (Zenmap), including both slow comprehensive and intense scan techniques, to ensure thorough enumeration of network services and system characteristics.

Across these scans, a total of 12 open ports (over TCP) were identified, primarily associated with enterprise services such as DNS, Kerberos, LDAP, SMB, and more. The scans analyzed up to 1000 ports and incorporated both TCP and UDP protocols, providing a comprehensive view of the system's network exposure.

Operating system detection was highly accurate, consistently identifying the host as Windows Server 2016 with a high confidence level. Additionally, the system was determined to be reachable within a single network hop, indicating direct accessibility within the network environment.

Overall, the results indicate a moderate attack surface, with multiple exposed services that could be leveraged for further enumeration or potential exploitation if misconfigured.

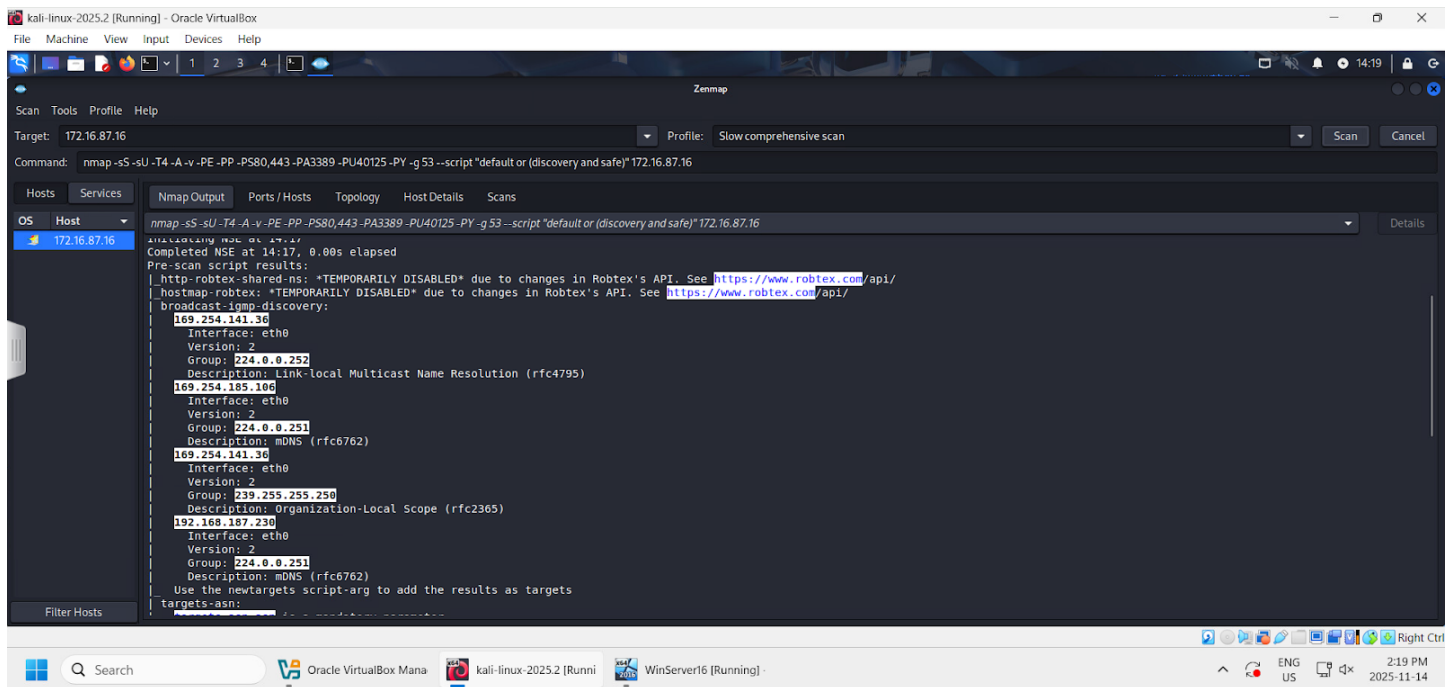


Figure 2: Slow Comprehensive Scan Execution

Nmap command used: `nmap -sS -sU -T4 -A -v -PE -PP -PS80,443 -PA3389 -OU40125 -PY -g53 --script "default or (discovery and safe)" 172.16.87.16`

This Nmap command performs a slow comprehensive scan against the target system (172.16.87.16) by conducting detailed TCP SYN and UDP scans, service and operating system detection, version enumeration, host discovery, and safe NSE script scanning to thoroughly identify open ports, active services, system information, and potential security weaknesses.

The scan performed in-depth enumeration using the Nmap Scripting Engine (NSE).

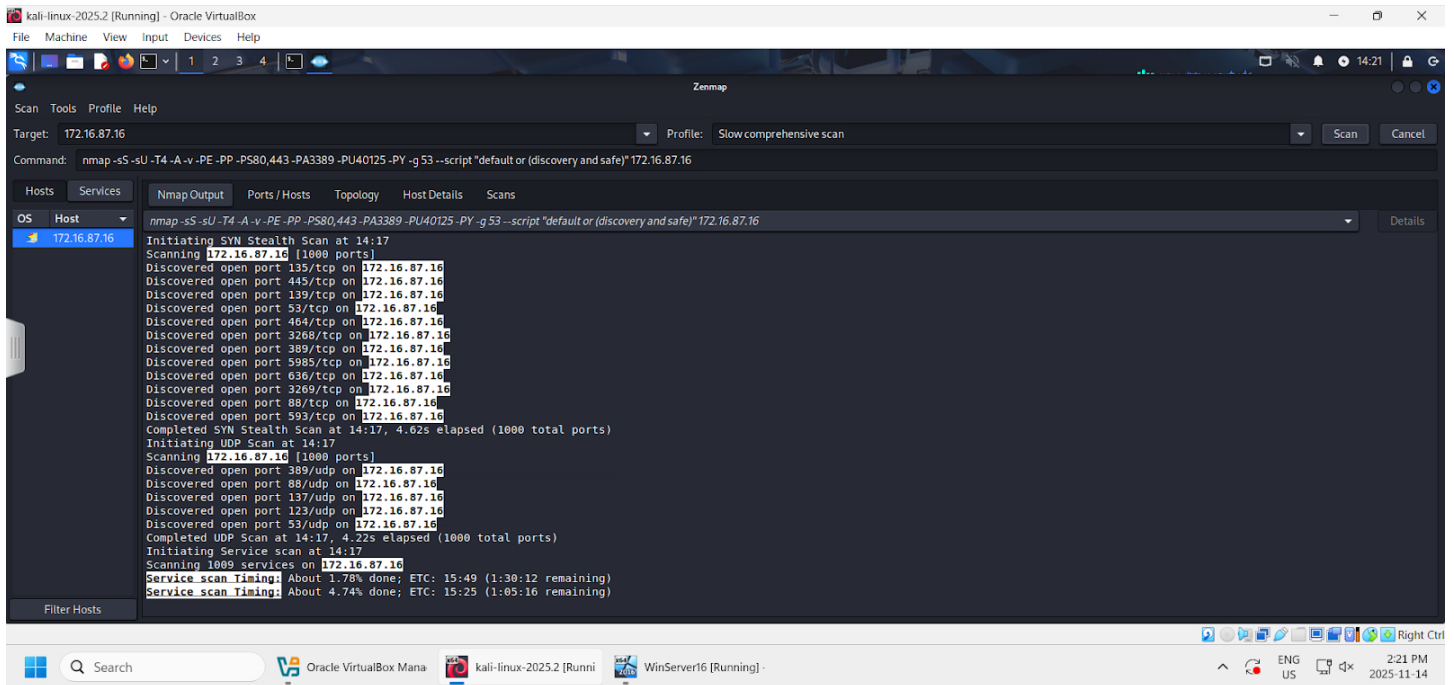


Figure 3: Open ports were discovered on the Windows Server 2016 VM using a slow comprehensive scan

A SYN stealth scan was performed across 1000 TCP ports, resulting in the identification of 12 open ports (over TCP). In addition, a UDP scan was conducted over the same range of 1000 ports, which revealed 5 open ports (over UDP).

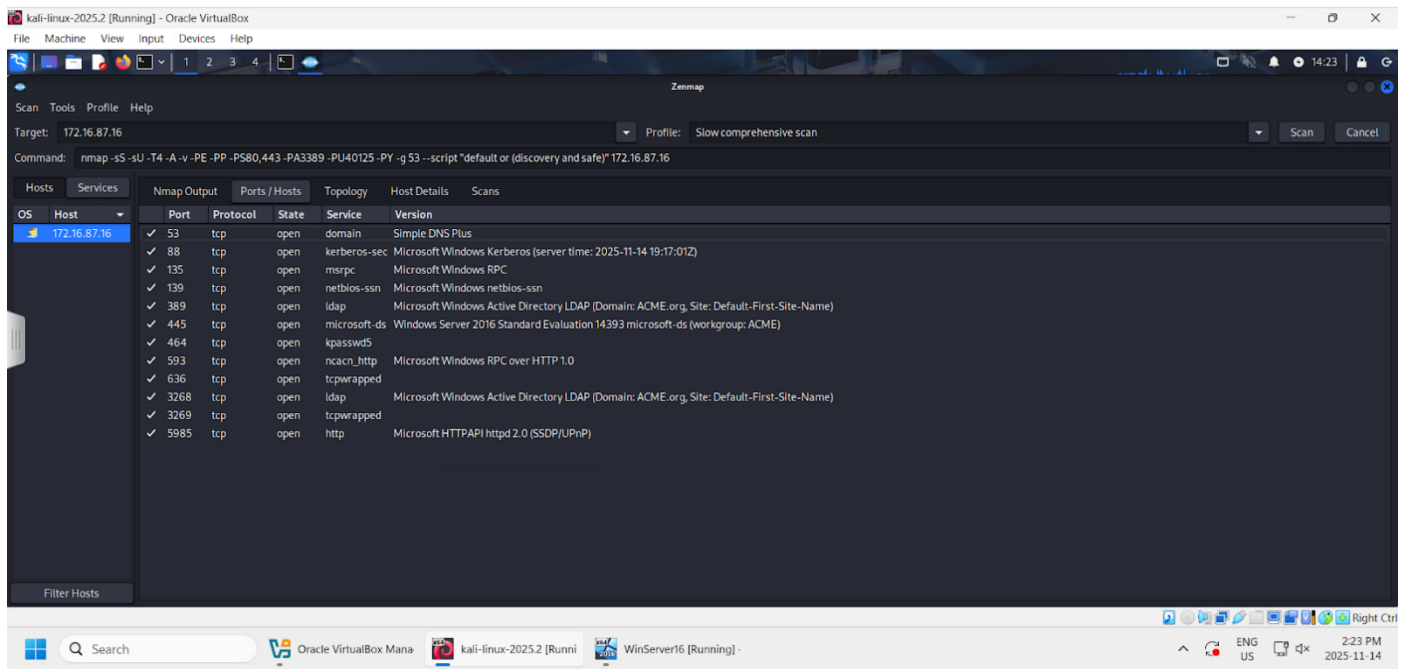


Figure 4: Open Ports, Services and Versions found using Comprehensive Scan

Service Name	Port(s)	Protocol	Description	Risk
Domain	53	TCP	Resolves hostnames to IP addresses and is essential for domain name resolution within the network.	Medium – Can be abused for tunneling, cache poisoning, or reconnaissance if misconfigured.
Kerberos-sec	88	TCP	Provides secure authentication using ticket-based mechanisms in Active Directory environments.	High – Targeted for credential attacks (e.g., Kerberoasting, ticket abuse).
LDAP	389, 3268	TCP	Directory service protocol used for querying and managing users, devices, and domain resources.	High – Can expose sensitive directory information and enable enumeration or credential attacks if unsecured.

Microsoft-ds	445	TCP	Enables file sharing and network resource access across Windows systems in a domain environment.	High – Commonly exploited for lateral movement, remote code execution, and credential theft.
NetBIOS-SSN	139	TCP	Legacy session service used for Windows network communication and file sharing.	High – Legacy protocol with known vulnerabilities and often targeted for enumeration and exploitation.
MSRPC	135	TCP	Supports Microsoft Remote Procedure Call for communication between distributed services.	High – Frequently used in remote exploitation, privilege escalation, and lateral movement attacks.
ncacn_http	593	TCP	Provides RPC (Remote Procedure Call) over HTTP, commonly used for remote administration and Windows services.	Medium-High – Can be abused for remote access or used as an additional attack surface for RPC services.
HTTP	5985	TCP	Web service protocol used for hosting web applications or administrative interfaces.	Medium – Vulnerable to web-based attacks such as misconfiguration, injection, or outdated software exploitation.
kpasswd5	464	TCP	Kerberos password change service used for securely	Medium – Can be targeted for credential

			updating authentication credentials.	manipulation if improperly secured.
tcpwrapped	3269,636	TCP	Indicates that the service is protected by TCP wrappers or access control rules limiting connections.	Low – Suggests access restrictions are in place, but may still be bypassed if misconfigured.

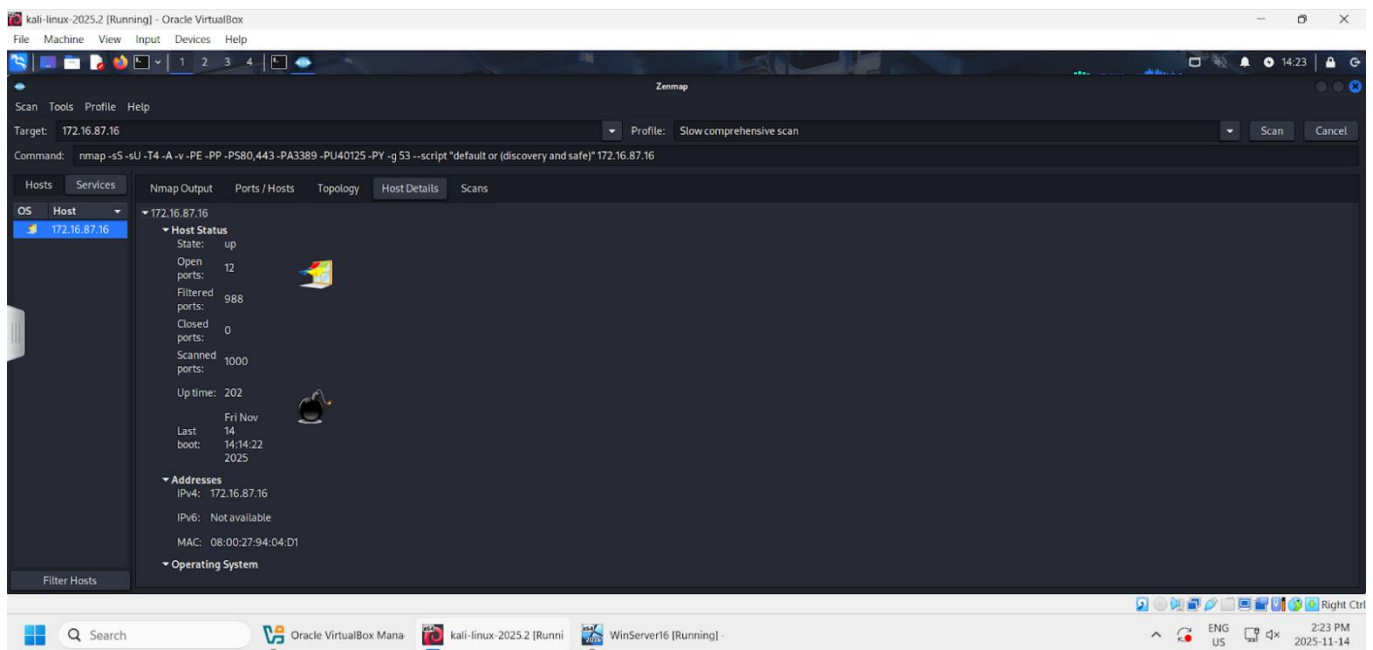


Figure 5: Host Details and Scan Statistics

The system was confirmed active with 12 open ports across 1000 scanned ports. The MAC address was also found, which is another key piece of information that attackers can use to identify the type of device.

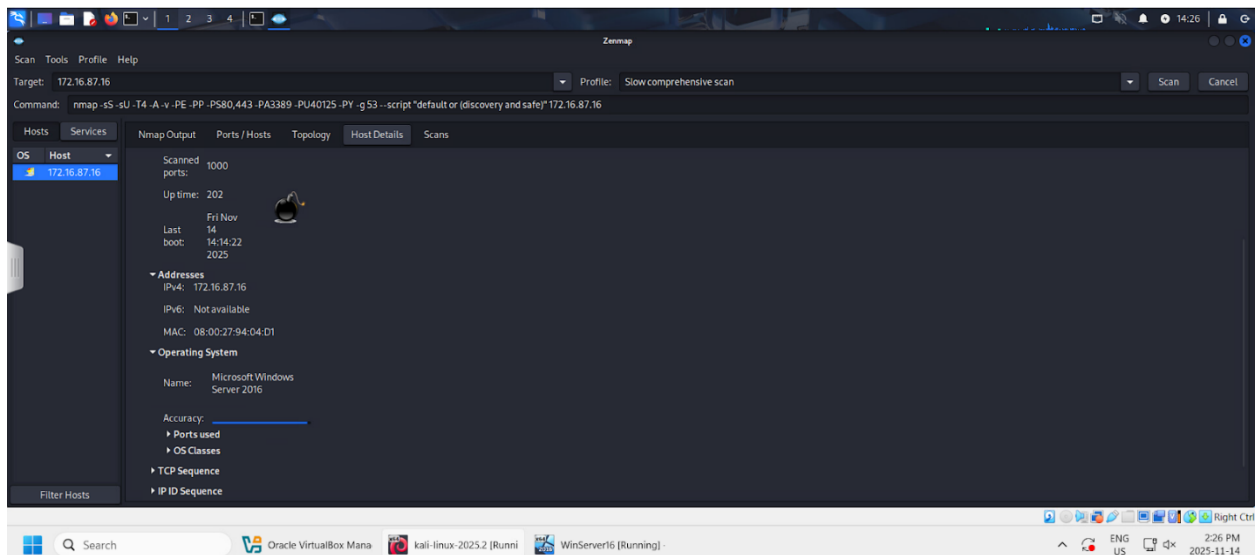


Figure 6: Operating System Detection

The system was accurately identified as Windows Server 2016 in the slow comprehensive scan. The MAC address was also identified, which could provide attackers with an idea of the target device type.

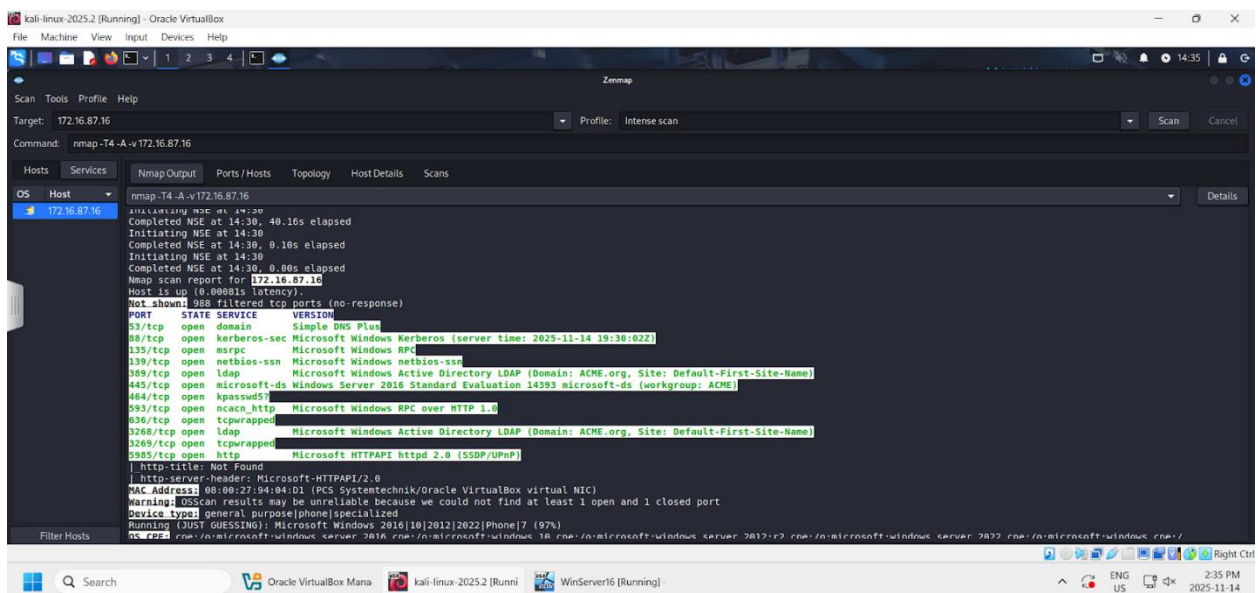


Figure 7: Intense Scan Results

Nmap command used: `nmap -T4 -A -v 172.16.87.16`

This command runs a fast, aggressive Nmap scan that discovers open ports, services, OS details, and other host information on 172.16.87.16.

The intense scan confirmed previously identified services using faster and aggressive timing (-T4).

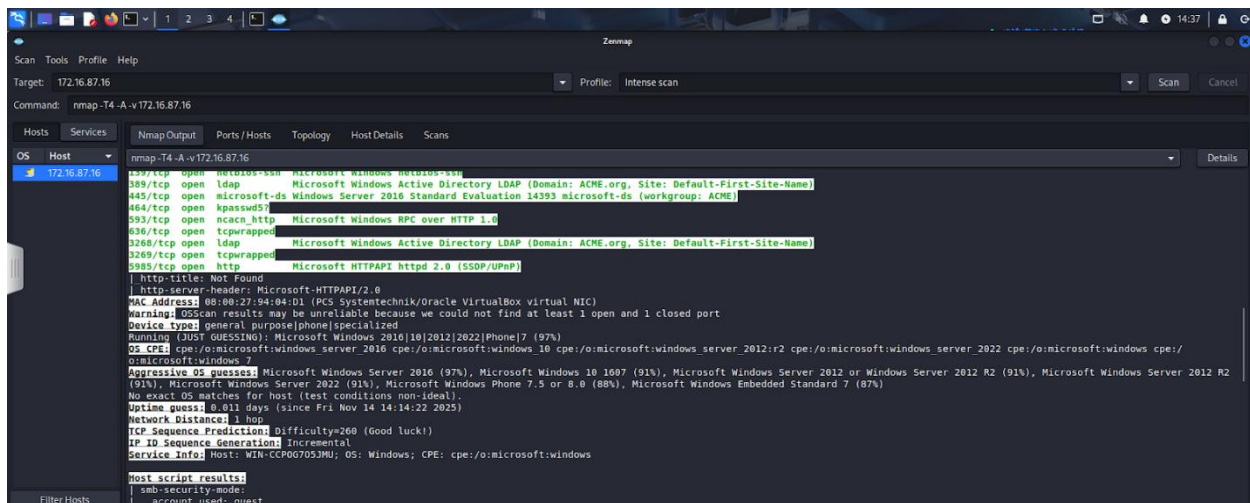


Figure 8: Aggressive OS detection identifying Windows Server 2016 (97% confidence) with TCP sequence prediction indicating high difficulty (260), suggesting strong resistance to session hijacking.

The scan results indicate a high-confidence identification of Microsoft Windows Server 2016 as the operating system, with a secondary match to Windows Server 2012. The network distance of 1 hop suggests the target is directly reachable within the local network segment. Additionally, the high TCP sequence prediction difficulty value (260) indicates strong resistance to sequence prediction attacks, reducing the likelihood of successful TCP session hijacking.

5.2 Windows Server 2012

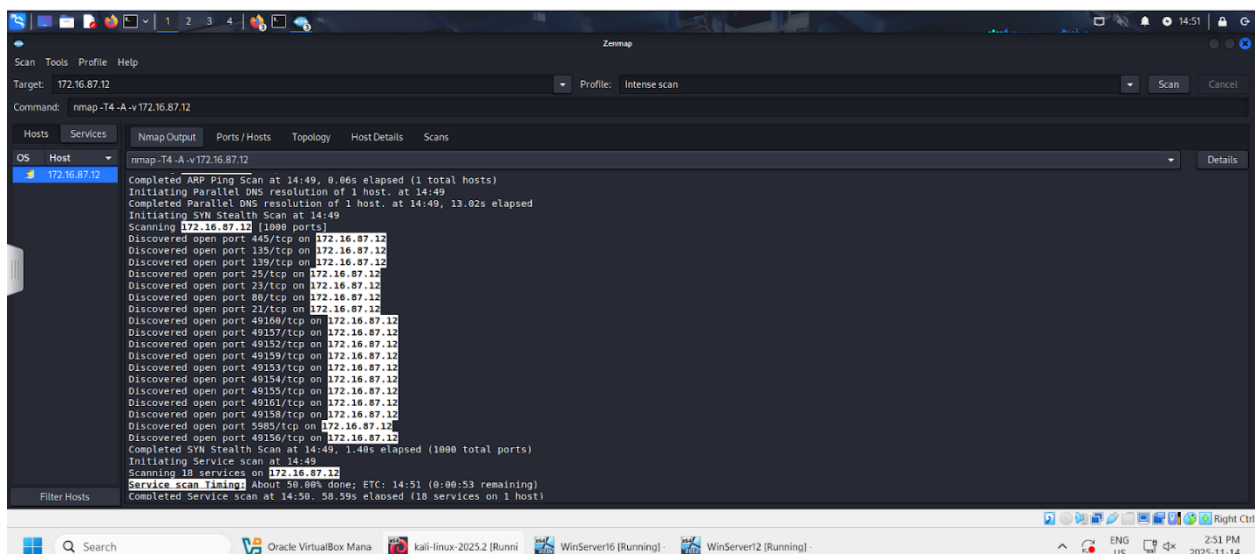


Figure 9: Intense scan results for Windows Server 2012 VM

Nmap command used: `nmap -T4 -A -v 172.16.87.12`

This command runs a fast, aggressive Nmap scan that discovers open ports, services, OS details, and other host information on 172.16.87.12.

The scan revealed and identified 18 open ports on the Windows Server 2012 VM (172.16.87.12).

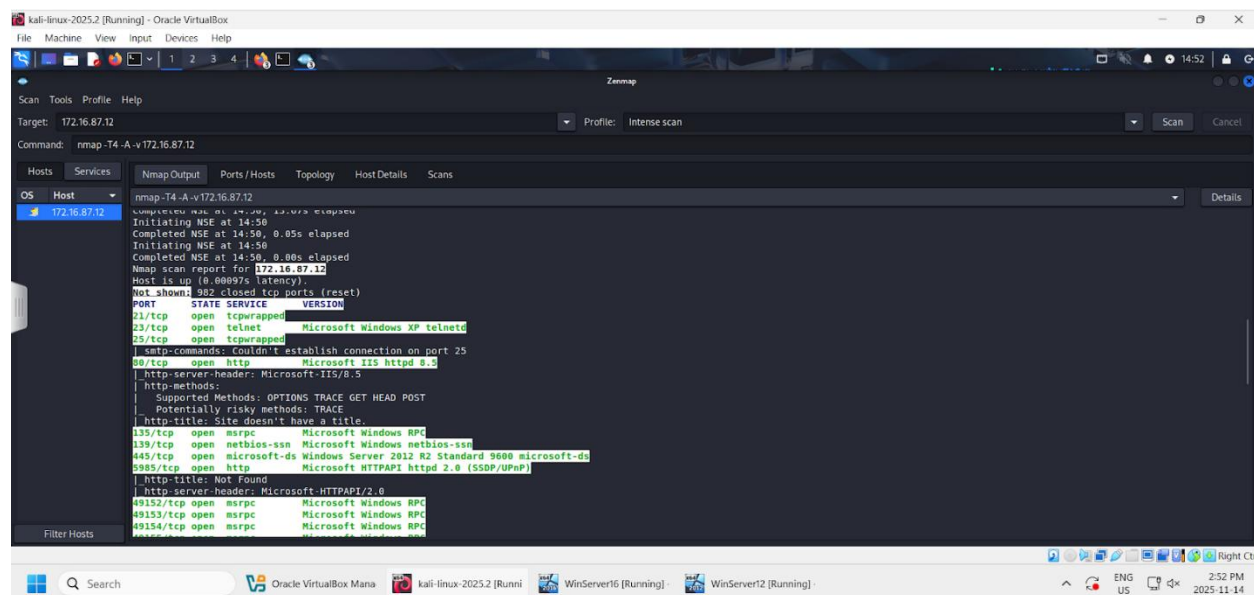


Figure 10: Open Ports and Services for Windows Server 2012 VM

Using the intense scan, multiple open ports and services were identified. Some of the open services were similar to those discovered from the virtual machine hosting Windows Server 2016.

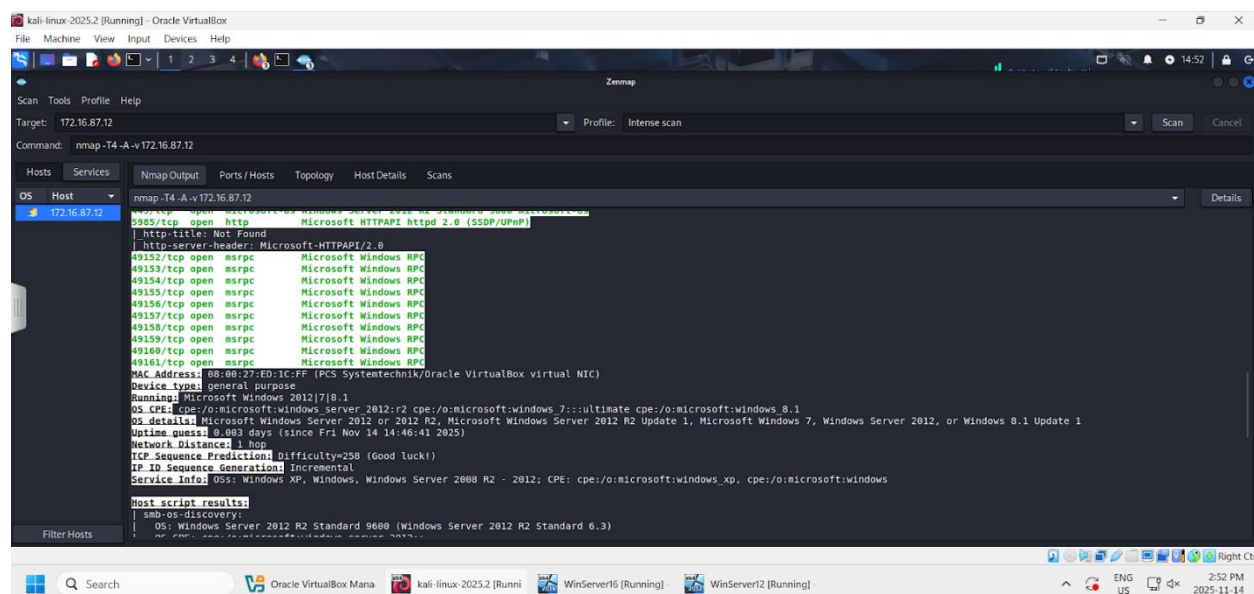


Figure 11: Intense scan results showing MAC address, device type, OS identification (Windows Server 2012), network distance, and TCP sequence prediction analysis

The scan provides detailed host information, including the MAC address, device type, and operating system identification, which was accurately determined to be Microsoft Windows Server 2012. The network distance indicates direct reachability within one hop. Additionally, the TCP sequence prediction analysis shows a high difficulty value of 258, suggesting strong resistance against sequence prediction attacks and reducing the risk of TCP session hijacking.

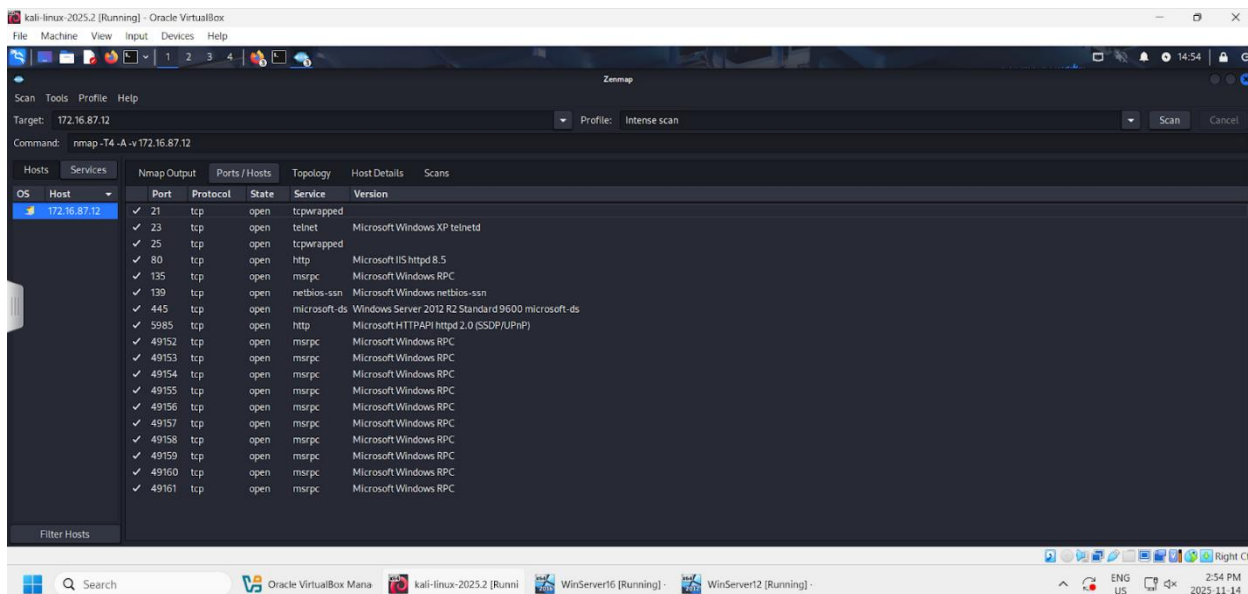


Figure 12: List of open ports and services for Windows Server 2012 VM

The Windows Server 2012 virtual machine has many of the same core services as Windows Server 2016, including DNS, LDAP, Kerberos, SMB, and MSRPC, indicating similar Active Directory and domain-related functionality. However, a notable difference is the presence of the Telnet service on port 23. Telnet is a legacy protocol that transmits data in plaintext, making it highly insecure compared to modern encrypted alternatives. Its presence increases the overall risk exposure of the system and may allow attackers to intercept credentials or sensitive session data if not properly restricted.

6.0 Vulnerability Analysis

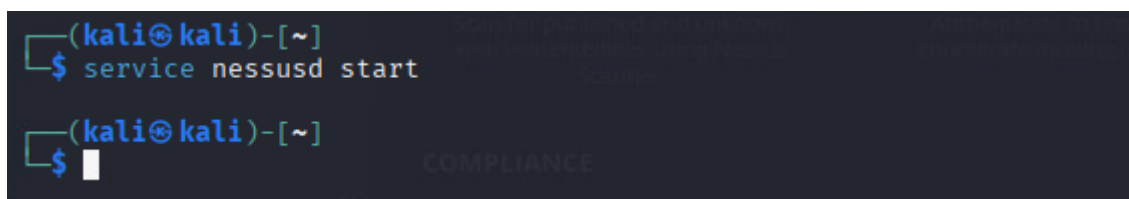


Figure 13: Launching Nessus with the Kali Linux environment

First, the vulnerability assessment was conducted using Nessus from a Kali Linux environment. The Nessus service was initiated via the command line using “service nessusd start”, which launched Nessus and enabled the web interface. Access to the Nessus console was then obtained through a web browser by navigating to <https://172.16.87.25:8834>, where authentication was performed using valid credentials.

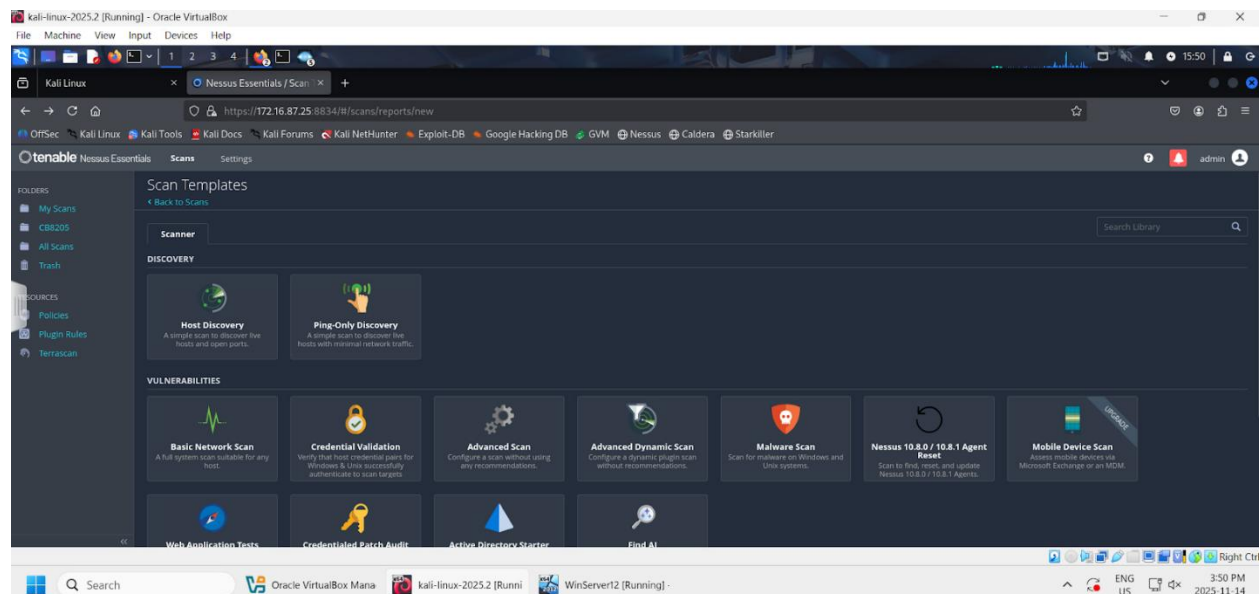


Figure 14: Executed an advanced scan against the virtual machine hosting Windows Server 2012

Once logged in, an advanced vulnerability scan was selected and executed against the target virtual machine hosting the Windows Server 2012.

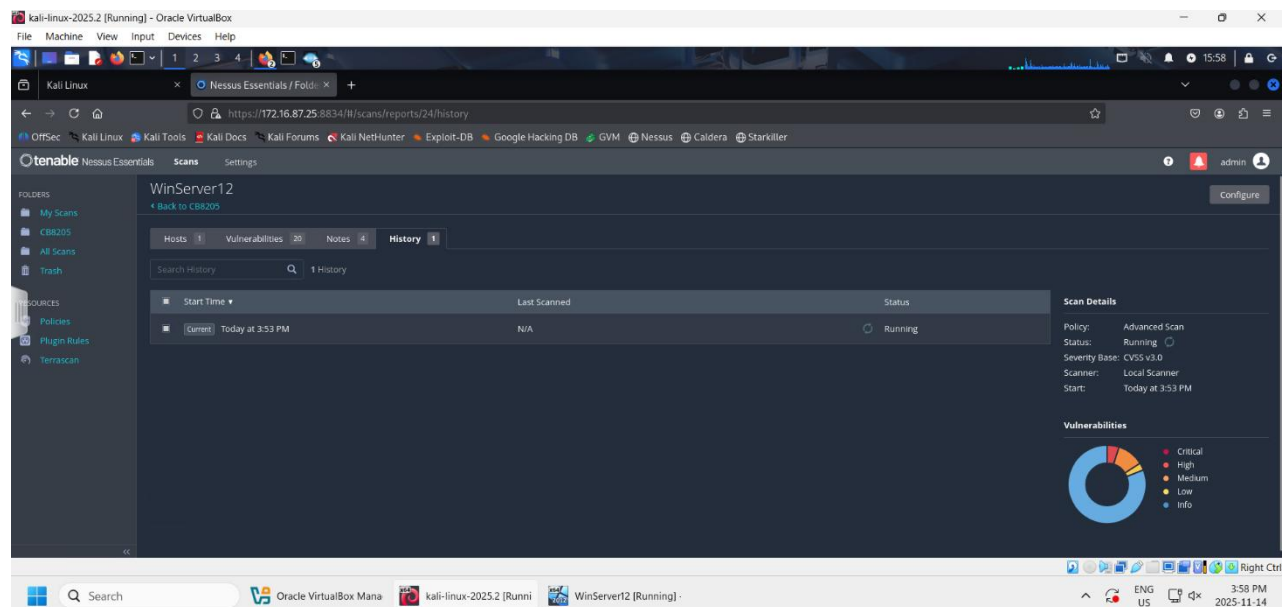


Figure 15: A local scanner was used for the advanced scan, and the severity base used was the CVSS v3.0.

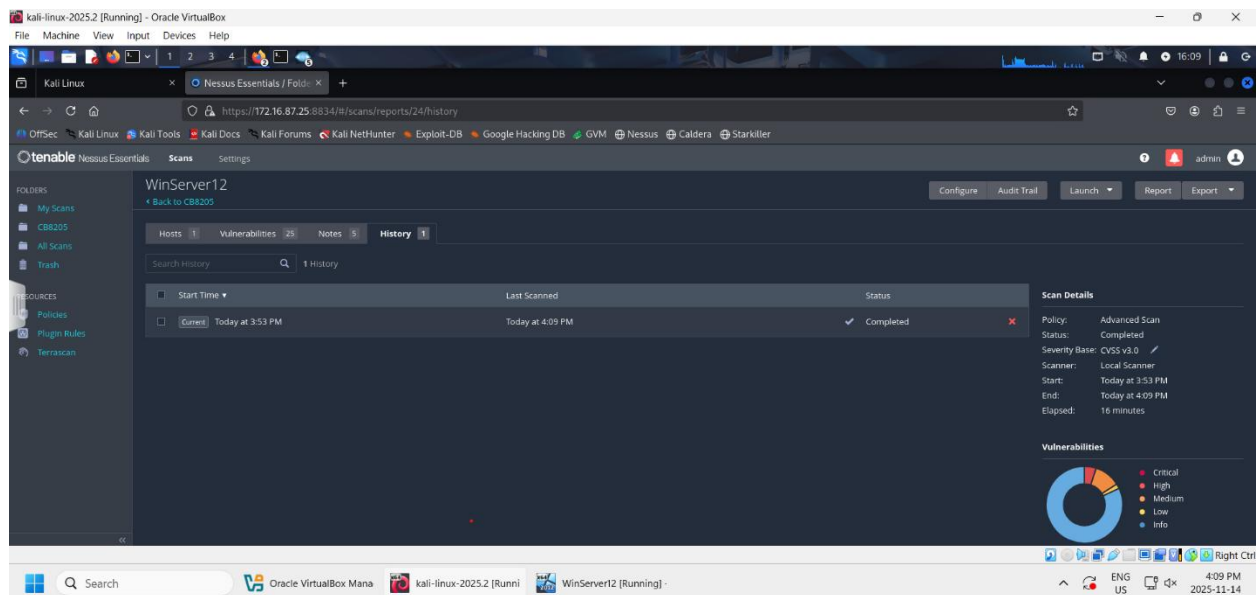


Figure 16: The advanced scan was completed and multiple vulnerabilities of several levels of severity were found.

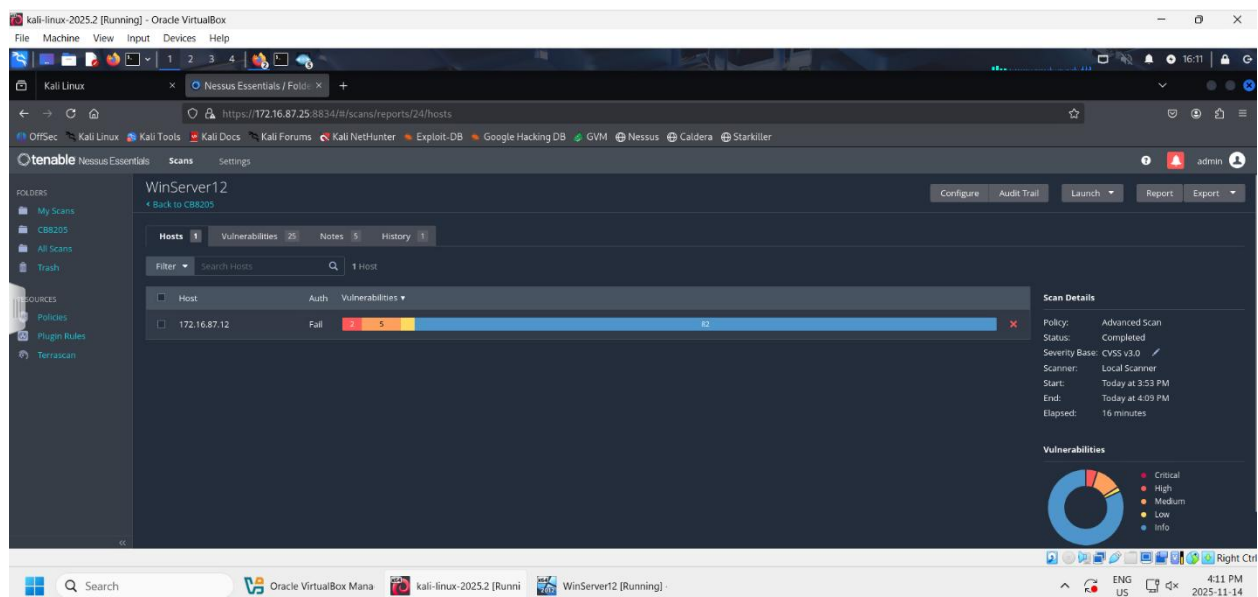


Figure 17: A severity-based distribution was presented to show the number of vulnerabilities for each level of severity

The scan completed in approximately 16 minutes and produced a severity-based vulnerability distribution that categorized findings into critical, high, medium, low, and informational levels. The results indicated 2 high, 5 medium, and 1 low-severity vulnerabilities, with the remaining findings classified as informational.

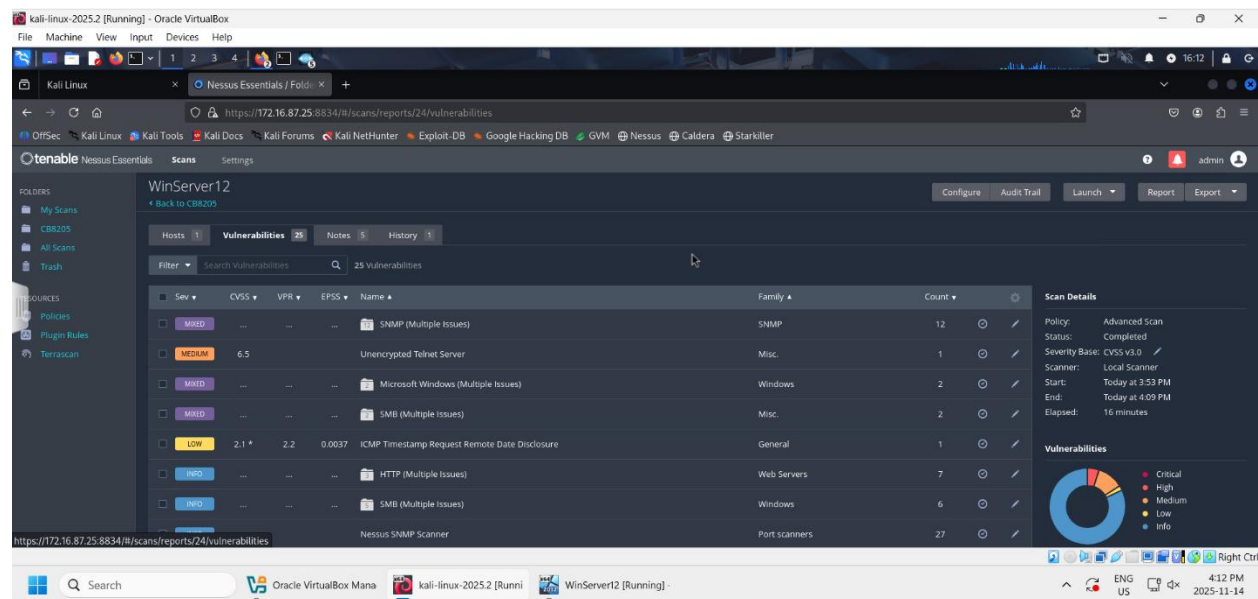


Figure 18: A list of different types of vulnerabilities from SNMP issues, unencrypted telnet server, Microsoft Windows issues, SMB issues, and more was shown.

The vulnerability results show that there are mixed-ranked vulnerabilities, such as SNMP issues, Microsoft Windows issues, and SMB issues. In addition, there was one medium-level vulnerability concerning an unencrypted Telnet server with a CVSS of 6.5. There was also one low-level vulnerability related to an ICMP timestamp request remote date disclosure with a CVSS of 2.1. The rest were informational vulnerabilities which reveal system information, such as software versions, open ports or user information, that attackers could use as a starting point to attack the system. This includes information on HTTP (web servers), SMB (Windows), and the Nessus SNMP Scanner (Port scanners).

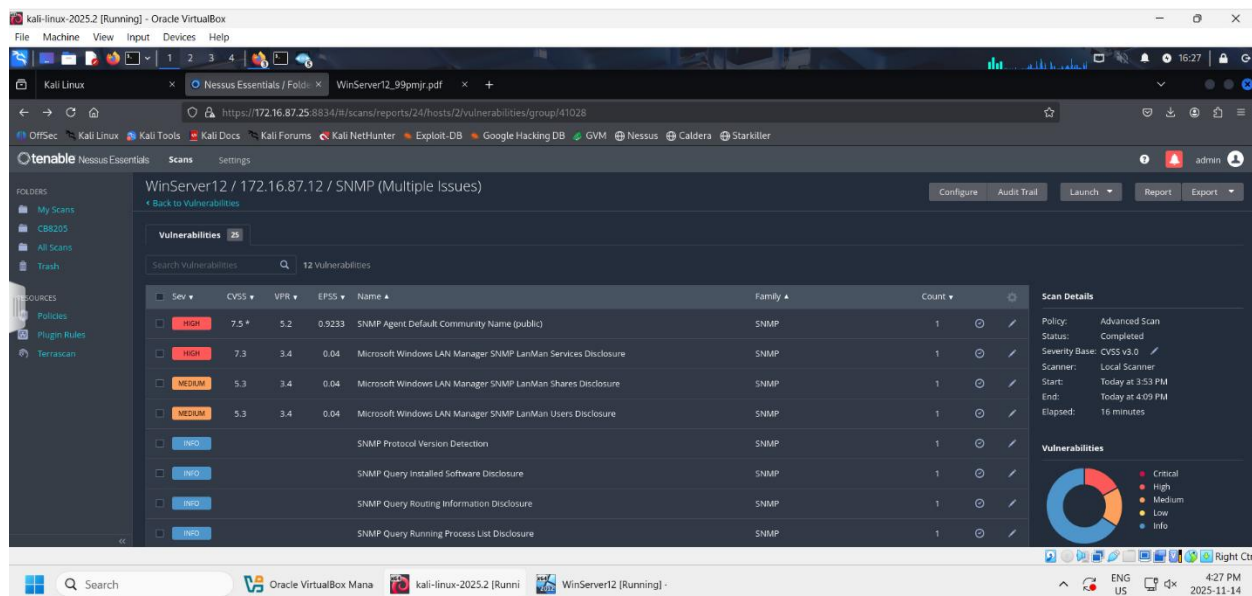


Figure 19: A breakdown of the different-level vulnerabilities as a part of the SNMP issues

A detailed review of the scan results revealed multiple security issues associated with SNMP services, including high-severity vulnerabilities such as the use of the default community string “public” (CVSS: 7.5) and Microsoft Windows SNMP-based LAN Manager service disclosure (CVSS: 7.3). These vulnerabilities are particularly concerning as they may allow unauthorized remote information gathering about system configuration and services, potentially aiding further exploitation. Furthermore, there were also medium-severity vulnerabilities, such as Microsoft Windows SNMP-based LAN Manager shares and user disclosures. Last, but not least, there were informational vulnerabilities such as SNMP protocol version detection, SNMP query installed software disclosure, SNMP query routing information disclosure, and SNMP query running process list disclosure.

High Severity Vulnerabilities:

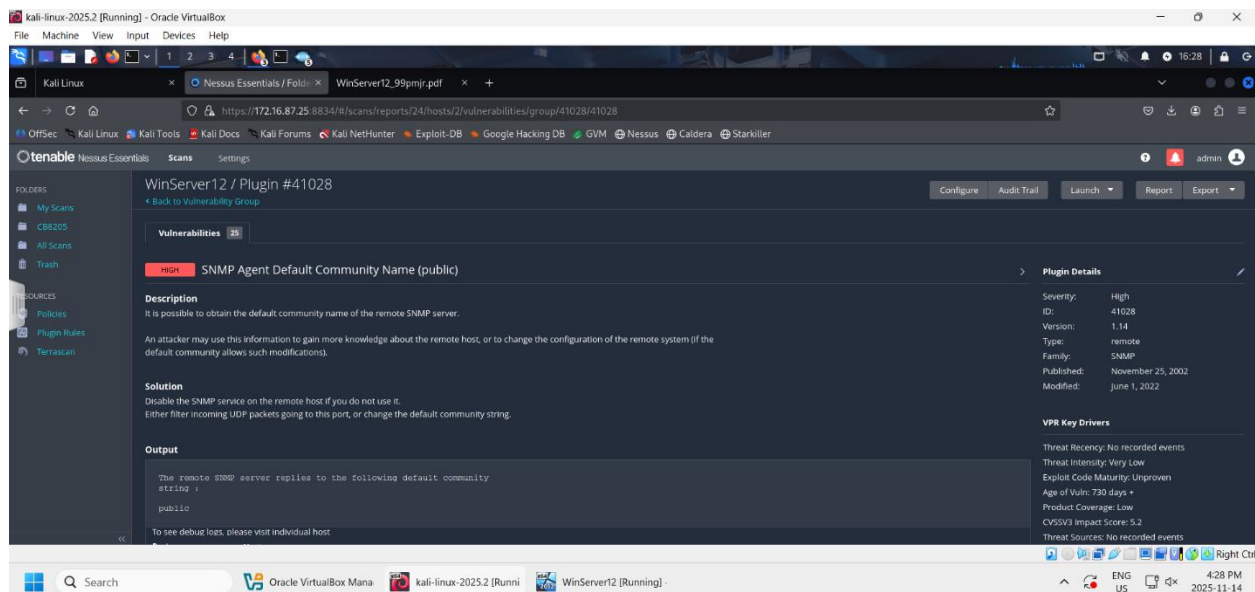


Figure 20: One of the top high-severity vulnerabilities in the SNMP was the SNMP Agent Default Community Name vulnerability

Vulnerability:

One of the high-severity vulnerabilities identified was the SNMP Agent Default Community Name vulnerability, where the default community name is set to “public.” This vulnerability belongs to the SNMP family and is classified as a remote vulnerability. There have been no recorded incidents related to this specific vulnerability; the threat intensity is considered low, and the exploit code maturity is unproven. Additionally, no threat sources have been reported. Furthermore, the CVSS v3 Impact Score for this vulnerability is 5.2, but the age of the vulnerability is 730 days.

Impact:

This SNMP vulnerability is dangerous because the default community name of the remote SNMP server may be exposed or easily guessed by attackers. As a result, attackers could gather sensitive information about the remote host or potentially modify the configurations of the remote system.

Recommended solutions:

A solution for this vulnerability was also provided. One recommendation was to disable the SNMP service on the remote host if it is not required. Another recommendation was to filter incoming UDP packets directed to the affected port or to change the default community string entirely. Another solution would be to enforce firewall rules and create access control lists that restrict SNMP access to only trusted IP addresses and network administrators. As a result, this would help prevent unauthorized systems from communicating with the SNMP service and reduce the risk of exploitation.

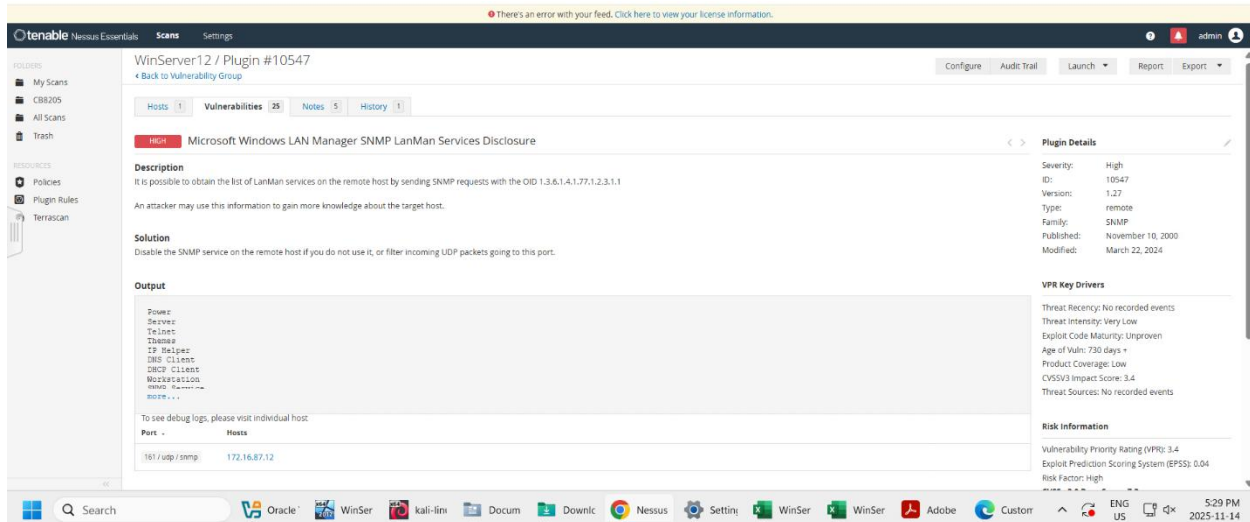


Figure 21: Another top high-severity vulnerability was the Microsoft Windows LAN Manager SNMP LanMan Services Disclosure vulnerability

Vulnerability:

Another high-severity vulnerability that was detected was the Microsoft Windows LAN Manager SNMP LanMan Services Disclosure vulnerability. This vulnerability is part of the SNMP family, and there have been no recorded threat events associated with it. The vulnerability allows attackers to obtain a list of LanMan services running on the remote host by sending SNMP requests using the OID 1.3.6.1.4.1.77.1.2.3.1.1. The CVSSv3 impact score is 3.4 and the age of the vulnerability is more than 730 days.

Impact:

An attacker could use the information gathered from this vulnerability to gain additional insight into the target host and its services. This information disclosure could assist attackers during the reconnaissance phase of an attack by helping them identify potential targets, services, or weaknesses within the system.

Recommended Solutions:

One recommended solution is to disable the SNMP service on the remote host if it is not required. Another recommendation is to filter or restrict UDP traffic directed to the SNMP port in order to limit unauthorized access to the service.

Medium Severity Vulnerabilities:

Unencrypted Telnet Server

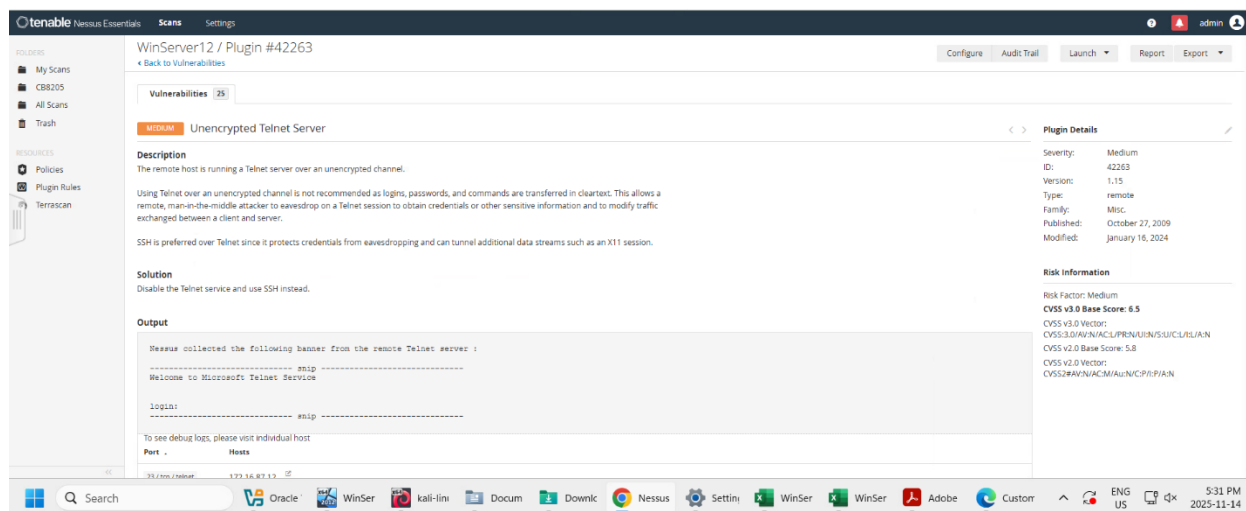


Figure 22: One of the medium-severity vulnerabilities found on the virtual machine hosting Windows Server 12 is an unencrypted telnet server.

Vulnerability:

Another vulnerability identified on the Windows Server 2012 target machine was the use of an unencrypted Telnet server. This vulnerability is classified as medium severity. The remote host was found to be running a Telnet service over an unencrypted communication channel, which is considered insecure because login credentials, passwords, and commands are transmitted in plaintext. The CVSS v3.0 base score is 6.5.

Impact:

This vulnerability could allow attackers to perform a man-in-the-middle attack to intercept and monitor Telnet sessions. As a result, attackers may be able to steal user credentials, capture sensitive information, or modify the traffic exchanged between the client and server. The use of Telnet significantly increases the risk of unauthorized access and information disclosure.

Recommended Solutions:

A recommended solution is to disable the Telnet service and replace it with SSH (Secure Shell), which provides encrypted communication for remote access. SSH helps protect sensitive data, credentials, and commands from being intercepted during transmission.

Microsoft Windows LAN Manager SNMP LanMan Shares Disclosure

Vulnerability:

Another medium-severity vulnerability identified was the Microsoft Windows LAN Manager SNMP LanMan Shares Disclosure vulnerability. This vulnerability allows attackers to obtain a list of shared resources on the remote Windows host by sending SNMP requests to the system. The disclosed

information may include shared folders and network resources that are accessible on the target machine. The CVSS v3.0 score is 5.3.

Impact:

An attacker could use the disclosed share information to gain a better understanding of the target system and its available network resources. This information could assist attackers during the reconnaissance phase of an attack and potentially help identify sensitive or improperly secured shared folders that could be targeted for unauthorized access.

Recommended Solutions:

A recommended solution is to disable the SNMP service if it is not required on the system. Additionally, administrators should restrict or filter SNMP traffic using firewalls or access control lists to prevent unauthorized SNMP requests. It is also recommended to secure shared resources by applying proper permissions and limiting unnecessary network shares.

Microsoft Windows LAN Manager SNMP LanMan users disclosure

Vulnerability:

Another medium-severity vulnerability identified was the Microsoft Windows LAN Manager SNMP LanMan Users Disclosure vulnerability. This vulnerability allows attackers to retrieve a list of user accounts on the remote Windows host through SNMP requests. The information is disclosed through specific SNMP Object Identifiers (OIDs) that expose details about local or domain users configured on the system. The CVSS v3.0 score is 5.3.

Impact:

An attacker could use the disclosed user account information to gain insight into valid usernames on the target machine. This information could assist in reconnaissance activities and may increase the likelihood of successful password attacks, brute-force attempts, or other forms of unauthorized access targeting known user accounts.

Recommended Solutions:

A recommended solution is to disable the SNMP service if it is not required on the system. If SNMP must remain enabled, access to the service should be restricted through firewall rules or access control lists to allow only authorized hosts. In addition, administrators should use secure SNMP community strings and apply the principle of least privilege to minimize information disclosure.

Low-Severity Vulnerabilities:

ICMP Timestamp Request Remote Date Disclosure

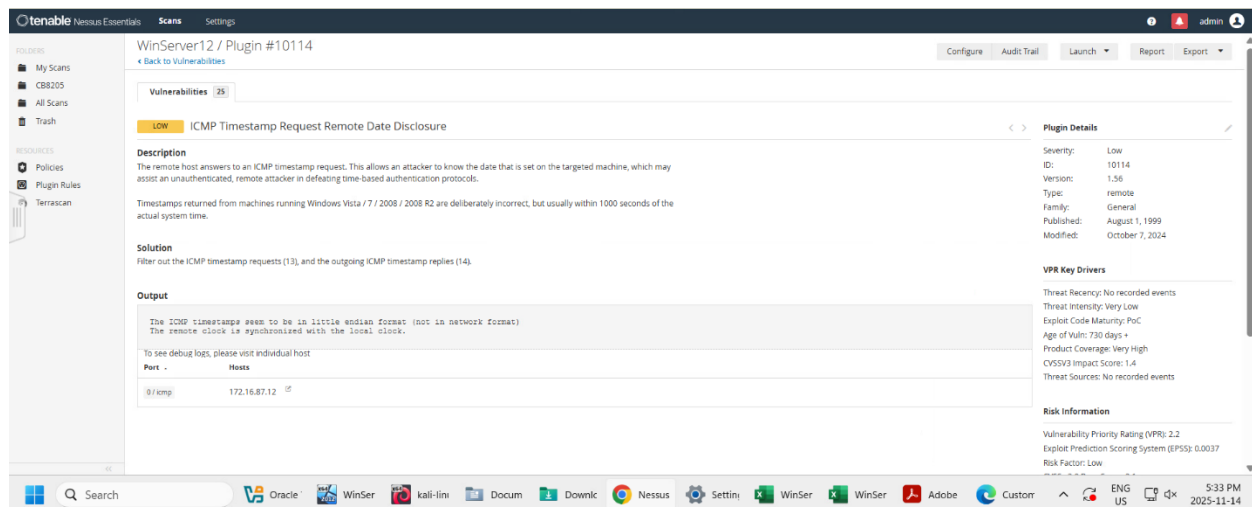


Figure 23: The advanced scan found a low-severity vulnerability, which was the ICMP Timestamp Request Remote Date Disclosure vulnerability.

Vulnerability:

A low-severity vulnerability identified on the target machine was the ICMP Timestamp Request Remote Date Disclosure vulnerability. This vulnerability occurs when a remote host responds to ICMP timestamp requests. As a result, attackers can determine the system date and time configured on the target machine.

Impact:

The disclosure of the system time may assist a remote and unauthenticated attacker in bypassing or weakening time-based authentication protocols. Although the vulnerability is considered low severity, it still exposes unnecessary system information that could aid attackers during reconnaissance activities. It was also reported that the product coverage for this vulnerability is very high, meaning that it affects multiple components or services on the target machine. The CVSS v3.0 score is 2.1.

Recommended Solutions:

A recommended solution is to filter and block incoming ICMP timestamp requests (Type 13) as well as outgoing ICMP timestamp replies (Type 14). Restricting these ICMP messages can help reduce unnecessary information disclosure and minimize the attack surface of the system.

7.0 Prioritized Risk Register and Overall Risk Assessment

Priority	Risk ID	Vulnerability	Severity	Likelihood	Potential Impact	Overall Risk	Recommended Mitigation
----------	---------	---------------	----------	------------	------------------	--------------	------------------------

1	R1	SNMP Agent Default Community Name (“public”)	High	High	Attackers may gain unauthorized access to sensitive SNMP information and potentially modify configurations.	High	Disable SNMP if unnecessary, change default community strings, and restrict SNMP access using ACLs and firewall rules
2	R3	Unencrypted Telnet Server	Medium	High	Credentials and sensitive information may be intercepted through man-in-the-middle attacks.	High	Disable Telnet and replace it with SSH for encrypted remote administration
3	R2	Microsoft Windows LAN Manager SNMP LanMan Services Disclosure	High	Medium	Attackers may enumerate running services and gather system intelligence for further attacks.	High	Restrict SNMP access, disable unused SNMP services, and filter UDP traffic to SNMP ports.
4	R5	Microsoft Windows LAN Manager SNMP LanMan Users Disclosure	Medium	Medium	Attackers may identify valid usernames and perform password attacks or unauthorized access attempts.	Medium	Disable unnecessary SNMP services and enforce strong access controls.
5	R4	Microsoft Windows LAN Manager SNMP LanMan Shares Disclosure	Medium	Medium	Shared resources may be enumerated, potentially exposing sensitive network shares.	Medium	Restrict SNMP access and secure shared resources using proper permissions.
6	R7	Multiple Exposed Administrative Services found on open ports (SMB, LDAP,	Medium	Medium	Exposed services increase the attack surface and may enable lateral	Medium	Restrict unnecessary ports, apply firewall rules, and segment the network where possible.

		Kerberos, MSRPC)			movement if compromised.		
7	R8	Legacy Protocol Exposure (NetBIOS)	Medium	Low-Medium	Legacy protocols may contain known vulnerabilities and insecure communication methods.	Low-Medium	Disable legacy protocols when possible and replace them with secure alternatives.
8	R6	ICMP Timestamp Request Remote Date Disclosure	Low	Low	System time information may assist attackers during reconnaissance activities.	Low	Block ICMP timestamp requests (Type 13) and replies (Type 14).

Risk Prioritization Approach

The risks identified during the assessment were prioritized based on vulnerability severity, likelihood of exploitation, and potential business and security impact. Greater emphasis was placed on attack path context, including service exposure, ease of exploitation, and potential for lateral movement within the environment. Factors such as accessibility of services, misconfigurations, and exposure of sensitive protocols were also considered to ensure prioritization reflected real-world attack scenarios rather than severity scores alone.

High-priority risks were assigned to vulnerabilities that could expose sensitive information, allow unauthorized access, or significantly assist attackers during reconnaissance and lateral movement activities.

Although the lab environment used a flat, non-segmented network architecture, all identified risks were still considered significant in isolation due to their potential impact if exploited.

Overall Risk Assessment

The overall risk posture of the assessed environment is classified as moderate to high due to the presence of multiple SNMP-related vulnerabilities, exposed administrative services, and insecure legacy protocols such as Telnet. Although no critical vulnerabilities were identified, the combination of information disclosure issues and insecure configurations significantly increases the attack surface of the target systems.

The most significant risks identified during the assessment were related to:

- SNMP misconfigurations and default community strings
- Information disclosure vulnerabilities

- Exposed administrative and domain-related services
- Unencrypted remote access protocols

If exploited, these vulnerabilities could allow attackers to gather sensitive system information, enumerate network resources and user accounts, intercept credentials, and potentially perform further attacks against the environment.

Several mitigating factors slightly reduce the immediate exploitation risk, including:

- No critical vulnerabilities identified
- Strong TCP sequence prediction difficulty values
- Some access restrictions identified on services

However, remediation and security hardening measures are still strongly recommended to reduce the attack surface and improve the overall security posture of the environment.

8.0 Recommendations for Remediation

Based on the findings from the vulnerability assessment and network scans, the following remediation measures are recommended:

SNMP Security Hardening

- Disable SNMP services if they are not required
- Replace default SNMP community strings such as “public” with strong and unique values
- Restrict SNMP access to trusted administrative systems using firewall rules and ACLs
- Upgrade to more secure SNMP versions where possible

Secure Remote Access

- Disable the Telnet service
- Replace Telnet with SSH for encrypted remote administration
- Enforce strong password policies and account protections

Reduce Information Disclosure

- Block ICMP timestamp requests and replies
- Restrict unnecessary service enumeration where possible
- Minimize exposed network shares and sensitive resources

Network Hardening

- Restrict unnecessary open ports and services

- Apply host-based and network-based firewall rules
- Implement network segmentation to reduce lateral movement opportunities

Patch and Configuration Management

- Regularly update operating systems and installed services
- Perform routine vulnerability scans and security assessments
- Review configurations against security hardening best practices

Monitoring and Access Control

- Implement centralized logging and monitoring
- Apply the principle of least privilege
- Monitor suspicious authentication attempts and network activity

Security Awareness and Administrative Practices

- Train administrators on secure configuration practices
- Maintain proper documentation of systems and exposed services
- Periodically review and remove unnecessary services from systems

9.0 Next Steps and Validation Activities

While the vulnerability assessment and network scans successfully identified multiple exposed services, misconfigurations, and potential security weaknesses, additional validation activities are recommended to determine whether the identified vulnerabilities are practically exploitable within the environment.

The scans performed during this assessment primarily focused on:

- Service discovery
- Port enumeration
- Operating system detection
- Vulnerability identification through automated scanning

Although automated tools such as Nessus and Nmap provide valuable insight into potential risks, some findings may represent informational exposure, theoretical weaknesses, or false positives that require manual verification.

The following next steps are recommended:

Vulnerability Validation

- Verify whether the identified vulnerabilities can be practically exploited
- Confirm whether vulnerable services are actively accessible from unauthorized systems
- Validate the effectiveness of existing security controls and access restrictions

Service Security Testing

- Perform authenticated testing against exposed services such as SMB, LDAP, Kerberos, and SNMP
- Assess whether weak credentials, default configurations, or unnecessary permissions exist
- Determine whether SMB shares or SNMP information disclosures expose sensitive data

Legacy Protocol Assessment

- Validate whether the Telnet service permits remote authentication
- Determine whether credentials are transmitted in plaintext within the environment
- Confirm whether legacy protocols are operationally required

Patch and Configuration Verification

- Verify whether systems are fully patched and updated
- Review system hardening configurations against security best practices
- Confirm whether unused services can be disabled safely

False Positive Analysis

- Review Nessus findings manually to identify potential false positives
- Cross-reference detected vulnerabilities with vendor advisories and patch status

Additional Security Testing

- Conduct authenticated vulnerability scanning where permitted
- Perform controlled penetration testing to evaluate exploitability and lateral movement risks
- Assess firewall rules, segmentation controls, and access management policies

Completing these validation activities would provide a more accurate understanding of the real-world risk associated with the identified vulnerabilities and help prioritize remediation efforts more effectively.

10.0 Lessons Learned

This vulnerability assessment provided valuable hands-on experience in network scanning, service enumeration, vulnerability analysis, and cybersecurity reporting within a controlled virtual lab environment.

Throughout the assessment, practical experience was gained using industry-standard tools such as Nmap, Zenmap, and Nessus to identify open ports, detect services, analyze operating systems, and assess security weaknesses across Windows Server environments.

One of the most important lessons learned was the significance of the reconnaissance and enumeration phases of a security assessment. Identifying exposed services such as SMB, LDAP, Kerberos, SNMP, and Telnet demonstrated how attackers may gather information about a target environment before attempting exploitation.

The assessment also reinforced the importance of:

- Proper service hardening
- Secure configuration management
- Limiting unnecessary network exposure
- Disabling insecure legacy protocols
- Applying the principle of least privilege

In addition, this project improved technical documentation and reporting skills by requiring vulnerability analysis, risk prioritization, remediation planning, and structured security reporting similar to real-world cybersecurity assessments.

The findings further demonstrated that even systems without critical vulnerabilities may still present significant security risks when multiple medium- and high-severity misconfigurations are combined.

Overall, this assessment strengthened practical knowledge in:

- Network security
- Vulnerability management
- Penetration testing methodologies
- Security analysis
- Risk assessment
- Cybersecurity reporting and communication

11.0 Conclusion

This vulnerability assessment successfully identified multiple exposed services, misconfigurations, and security weaknesses across the Windows Server 2012 and Windows Server 2016 virtual machines within the lab environment.

Using a combination of network scanning and vulnerability assessment tools, the assessment revealed several high-, medium-, and low-severity vulnerabilities related to SNMP configurations, information disclosure, exposed administrative services, and insecure legacy protocols such as Telnet.

The results highlighted the importance of proactive vulnerability management, secure configuration practices, and continuous monitoring to reduce the overall attack surface of enterprise systems. Although no critical vulnerabilities were identified, the assessment demonstrated how information disclosure vulnerabilities and insecure services could still provide attackers with valuable reconnaissance opportunities and potential attack paths.

The remediation recommendations and risk prioritization strategies outlined in this report provide a foundation for improving the security posture of the assessed environment through service hardening, network segmentation, secure remote access practices, and regular vulnerability assessments.

Overall, this project provided practical experience in conducting vulnerability assessments, analyzing security risks, and developing professional cybersecurity documentation aligned with industry practices.